

Time for security

Once a DDoS attack starts on a Web server, it is extremely difficult to stop it. But, if the following security steps are practised, then the attack can be curbed to a large extent:

- Implementing CAPTCHAs can hinder automated DDoS attacks. Though bots are increasingly finding ways to circumvent CAPTCHAs, they are still an effective defence against application DDoS attacks.
- DDoS attacks are almost always performed by an automated client. Many of these client or bot agents have unique characteristics that differentiate them from regular Web browser agents. Tools/technologies that recognise bot agents, such as malware collectors and honey-pots, can help in bot-net analysis, thus improving security.
- Administrators could adjust their network gateways in order to filter input and output traffic. The source IP address of output traffic should belong to the local subnet, whereas the source IP address of input traffic should not. In this way, they can reduce traffic on the network that has spoofed IP addresses.
- If you own a Web server, don't just rely on anti-viruses, but instead use fully updated anti-malware and anti-bot-net software too. In this way, you can prevent auto installation of DDoS tool-kits on your system. Moreover, always keep your systems updated and fully patched.
- Intrusion detection systems (IDS/IPS) can be a great help here in notifying the administrator if someone is trying to break in to install attack tool-kits or bots.

Securing Apache from DDoS

- The limit on the number of simultaneous requests that will be served by Apache is decided by the `MaxClients` directive, and is set to 256, by default. Any connection attempts over this limit will normally be queued, up to a number based on the `ListenBacklog` directive, which is 511, by default. However, it is best to increase this, to prevent TCP SYN flood attacks.
- Using traffic-shaping modules: Traffic shaping is a technique that establishes control over Web server traffic. Many Apache modules perform traffic shaping, and their goal is usually to slow down a (client) IP address, or to control the bandwidth consumption on the per-virtual-host level. On the positive side, these can also be used to prevent DDoS attacks. The following are some popular traffic shaping modules:
 - `mod_limitipconn` (<http://dominia.org/djao/limitipconn.html>) limits the number of simultaneous downloads permitted from a single IP address.
 - `mod_throttle` (http://dir.filewatcher.com/d/RedHat7.3/i386/System%20Environment/Daemons/mod_throttle-3.1.2-5.i386.rpm.32319.html) is intended to reduce the load on your server, and the data transfer generated by popular virtual hosts, directories, locations, or users.

- `mod_bwshare` (<http://www.topology.org/src/bwshare/README.html>) accepts or rejects HTTP requests from each client IP address, based on past downloads by that client IP address.
- Apart from the above, one module that is designed specifically as a remedy for Apache DoS attacks is `mod_dosevasive` (http://tools.10t3k.net/Hardening/mod_dosevasive.1.9.tar.gz). This module will allow you to specify a maximum number of requests executed by the same IP address. If the threshold is reached, the IP address is blacklisted for the time period you specify. The only problem with this module is that users, in general, do not have unique IP addresses. Many users browse through proxies, or are hidden behind a *network address translation* (NAT) system. Blacklisting a proxy will cause all users behind it to be blacklisted. Hence, it is recommended to keep traffic shaping modules higher in your priority list.

Tools of the secure trade

- (D)DoS Deflate (<http://deflate.medialayer.com/>) is a lightweight Bash shell script designed to assist in the process of blocking a denial of service attack.
- Apache log viewer (<http://www.apacheviewer.com/index.php>), which is a free tool, can be used for easy analysis of Web server traffic and requests. Other tools such as `zmbsecap-0.1` and `scrutinizer-1.03` are also effective. You can get a huge list of such tools at <http://packetstormsecurity.org/distributed/>.



Note: I once again stress that neither I nor LFY are responsible for the misuse of the information given here. Rather, the attack techniques are meant to give you the knowledge that you need to protect your own infrastructure. Please use the tools and techniques discussed in this article, sensibly.

We will deal with other dangerous attacks on Web applications and Apache in the next article. Always remember: *Know hacking, but no hacking.* 

Further reading

- [1] http://en.wikipedia.org/wiki/Denial-of-service_attack
- [2] <http://dos-attacks.com/> contains latest news/information on DoS attacks.

By: Arpit Bajpai

The author is a FOSS enthusiast and loves to troubleshoot in the information security domain, while exploring new exploits and system vulnerabilities. You can send your queries and constructive feedback on the article, to abajpai75 AT yahoo DOT com.